

Linux系统基线加固一

笔记本：linux加固

创建时间：2018/11/1 11:18

更新时间：2018/11/1 11:29

作者：苏醒

URL：https://www.cnblogs.com/ksufer/p/7111767.html?utm_source=itdadao&utm_medium=referral

一、账号管理、认证授权

第一部分主要是对用户账号和权限进行加固，主要用到的命令主要是一些文件查看与编辑类的命令。

1、与账号、用户组、密码等有关文件

这些文件包括：

/etc/passwd

/etc/shadow

/etc/group

简单说明一下：

/etc/passwd 记录了系统中各用户的一些基本属性，root可写，所有用户可读，查看可见如下信息：

```
root:x:0:0:root:/root:/bin/bash      root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin     bin:x:1:1:bin:/bin:/sbin/nologin
```

用“：”隔开的各部分含义为：

用户名:口令:用户标识号:组标识号:注释性描述:主目录:登录Shell

其中口令由于安全考虑，被记录在了 /etc/shadow 文件中，所以这里统一显示为x。

/etc/shadow 负责所有用户的密码：

```
root:$1$1U7eND84$ekaAdUrEZEjSZjYIV4HC1/:0:99999:7:::
bin:!:17110:0:99999:7:::
```

与passwd文件相似，各字段也被“：”隔开，其含义为：

登录名:加密口令:最后一次修改时间:最小时间间隔:最大时间间隔:警告时间:不活动时间:失效时间:标志（系统保留）

这里有几点需要说明：

（1）“口令”字段存放的是加密后的用户口令字，如果为空，则对应用户没有口令，登录时不需要口令；星号代表帐号被锁定，有些系统为NP；双叹号表示这个密码已经过期了。

\$6\$开头的，表明是用SHA-512加密的

\$1\$ 表明是用MD5加密的

\$2\$ 是用Blowfish加密的

\$5\$ 是用SHA-256加密的。

(2) “最后一次修改时间”表示的是从某个时刻起，到用户最后一次修改口令时的天数。时间起点对不同的系统可能不一样。例如1970年1月1日。（后面所有时间均以此时间为起点）

(4) “最小时间间隔”指的是两次修改口令之间所需的最小天数。

(5) “最大时间间隔”指的是口令保持有效的最大天数。

(6) “警告时间”字段表示的是从系统开始警告用户到用户密码正式失效之间的天数。

(7) “不活动时间”表示的是用户没有登录活动但账号仍能保持有效的最大天数。

(8) “失效时间”字段给出的是一个绝对的天数，如果使用了这个字段，那么就给出相应账号的生存期。

/etc/group 负责用户组属性：

```
root:x:0:
bin:x:1:
```

其中，组内用户列表中，用户间用“，”隔开。

如果想要查看一个用户的用户组信息，可以使用

```
id [user]
```

```
[root@localhost ~]# id root
uid=0(root) gid=0(root) groups=0(root)
```

来查看：

2、锁定无关账户

在确认某些账户可以锁定的情况下，可以使用

```
passwd -l [user]
```

其原理是在/etc/shadow中用户的密码字段前加入“!!”（因系统而异，有些系统是加入“*LK*”），使得用户密码改变，无法登陆

```
ksufer:!!$1$RtXM74iB$CSv/HN8bjniHAB78M3x03/:17350:0:99999:7:::
```

这还真是简单粗暴，不过这也意味着，只要随意修改shadow文件密码字段，即可实现账号锁定。

对应的解锁命令为

```
passwd -u [user]
```

3、禁止超级管理员账户远程登录

在进行这方面工作之前，首先要知道一个重要内容 Linux-PAM（Linux可插拔认证模块）。

用户可以通过修改配置文件/etc/pam.conf（RedHat等系统还支持另外一种配置方式，即通过配置目录/etc/pam.d/）对认证机制进行修改，而个模块的具体配置在/etc/security下。

具体相关知识由于篇幅，可以自行百度，（推荐一篇[博客](#)，很实用）这里只对本小节内容进行说明。



1 PAM工作机制

/lib/security

目录下的每一个认证模块都会返回pass或者fail结果，部分程序使用/etc/security目录下的设置文件决定认证方式。

应用程序调用PAM模块认证的配置，存放于/etc/pam.d，文件名与应用程序名对应，文件中的每一行都会返回一个成验证功还是失败的控制标志，以决定用户是否拥有访问权限。

2 PAM验证类型

- * auth 验证使用者身份，提示输入账号和密码
- * account 基于用户表、时间或者密码有效期来决定是否允许访问
- * password 禁止用户反复尝试登录，在变更密码时进行密码复杂性控制
- * session 进行日志记录，或者限制用户登录的次数 libpam函数库会可以调用以上一种服务或者全部。

3 PAM验证控制类型(Control Values)

验证控制类型也可以称做Control Flags，用于PAM验证类型的返回结果。

- * required 验证失败时仍然继续，但返回Fail(用户不会知道哪里失败)
- * requisite 验证失败则立即结束整个验证过程，返回Fail
- * sufficient 验证成功则立即返回，不再继续，否则忽略结果并继续
- * optional 无论验证结果如何，均不会影响(通常用于session类型)



打开/etc/pam.d/login文件，可以看到如下内容：

```
#%PAM-1.0_
auth [user_unknown=ignore success=ok ignore=ignore default=bad] pam_securetty.so
auth      substack      system-auth
auth      include       postlogin
account   required      pam_nologin.so
account   include       system-auth
password  include       system-auth
# pam_selinux.so close should be the first session rule
session   required      pam_selinux.so close
session   required      pam_loginuid.so
session   optional      pam_console.so
# pam_selinux.so open should only be followed by sessions to be executed in the user context
session   required      pam_selinux.so open
session   required      pam_namespace.so
session   optional      pam_keyinit.so force revoke
session   include       system-auth
session   include       postlogin
-session  optional      pam_ck_connector.so
```

其中

auth [user_unknown=ignore success=ok ignore=ignore default=bad] pam_securetty.so

或

auth required pam_securetty.so

处于未注释状态，再查看/etc/securetty中没有pts/x（x为一个十进制整数）或已被注释掉

确保root不能通过telnet连接主机。

再检查SSH：

/etc/ssh/sshd_config

检查下列行设置是否为no并且该行未被注释：PermitRootLogin

```
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

然后重新启动ssh服务：

```
service sshd stop
```

```
service sshd start
```

4、修改用户组

使用usermod -g [group/GID] [username] 修改用户组。没什么好说的，上图：

```
[root@localhost ~]# id ksufer
uid=1000(ksufer) gid=1000(ksufer) groups=1000(ksufer)
[root@localhost ~]# usermod -g root ksufer
[root@localhost ~]# id ksufer
uid=1000(ksufer) gid=0(root) groups=0(root)
```

5、口令策略

(1) 口令复杂度及时效

修改 /etc/login.defs，文件注释很清楚，可以自己修改：

```
# Password aging controls:
#
#      PASS_MAX_DAYS   Maximum number of days a password may be used.
#      PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#      PASS_MIN_LEN     Minimum acceptable password length.
#      PASS_WARN_AGE    Number of days warning given before a password expires.
#
PASS_MAX_DAYS   99999
PASS_MIN_DAYS   0
PASS_MIN_LEN     5
PASS_WARN_AGE    7
```

(2) 设定密码历史，不能重复使用近N次内已使用的口令（方法来自网络）

对于Redhat系列的Linux，查看/etc/pam.d/system-auth

对于Debian系列的Linux，查看/etc/pam.d/common-password

在如图所示的行后，加入remember=N

```
password    requisite    pam_pwquality.so try_first_pass local_users_only retry=3 authtok_type=
password    sufficient   pam_unix.so md5 shadow nullok try_first_pass use_authtok remember=5
password    required      pam_deny.so
```

但我目前有一个疑问，remember=N这个语句的PAM验证控制类型是否应该是sufficient而不是其他类型。但求大神指导！

(3) 设定连续认证失败次数超过N次锁定该账号

依然是修改/etc/pam.d/login文件的第二行，加入如下命令

```
auth required pam_tally2.so deny=3 lock_time=300 even_deny_root root_unlock_time=10
```

```
#%PAM-1.0
auth required pam_tally2.so deny=3 unlock_time=60 even_deny_root root_unlock_time=10_
auth [user_unknown=ignore success=ok ignore=ignore default=bad] pam_securetty.so
```

6、设定文件目录权限

在用户登录中，passwd、shadow、group文件非常重要，需要严格管理文件权限

/etc/passwd 必须所有用户都可读，root用户可写 -rw-r--r-- 权限值为644

/etc/shadow 只有root可读 -r----- 权限值为400

/etc/group 必须所有用户都可读，root用户可写 -rw-r--r-- 权限值为644

使用如下命令修改权限：

```
chmod 644 /etc/passwd
chmod 400 /etc/shadow
chmod 644 /etc/group
```

此外还有一个重要的参数 umask，其值确定了新建目录文件的默认权限，这里先给出我们推荐的值 027

在权限设定中 r=4;w=2;x=1 但对于umask来说，umask=777（666）-权限值，即权限值=777（666）-umask。例如，umask=002，所对应的文件和目录创建缺省权限分别为6 6 4(666-2)和7 7 5(777-2)。

为什么是这样的呢？对于文件来说，这一数字的最大值分别是6。系统不允许你在创建一个文本文件时就赋予它执行权限，必须在创建后用chmod命令增加这一权限。目录则允许设置执行权限，这样针对目录来说，umask中各个数字最大可以到7。

如果使用推荐值umask=027，则对于文件来说，其权限为640，即-rw-r-----，对目录来说，其权限为750，即-rwxr-x---

7、检查是否存在除root之外UID为0的用户

使用如下代码，对passwd文件进行检索：

```
awk -F ':' '($3==0){print $1}' /etc/passwd
```

将检索出来的不是root的用户使用userdel命令全部删除。